GWENDAL LE COGUIC

COURSES

Each training session focuses on practical demonstrations, interactive exercises, and discussions based on real-life situations to ensure the acquisition of key skills.

Each session can be taken:

- on-site or remotely
- in French or English
- individually or in groups

Quotes available upon request

Tel: +33 7 69 02 25 10
Email: contact@glc.st

LARAVEL SECURITY



a. Description

*This one-day course is designed for **Laravel developers** who want to build secure applications from the ground up. You'll learn to **identify common vulnerabilities**, **apply Laravel's built-in protections**, and **adopt best practices** to secure authentication, **authorization**, **input validation**, and more.*

b. Educational goals

- Recognize common web vulnerabilities and Laravel's protections
- Implement secure authentication and authorization with Laravel tools
- Configure CORS and CSRF protections properly
- Validate and sanitize user input securely
- Handle file uploads and storage with security in mind

c. Prerequisites

- Good experience with PHP and Laravel framework
- Understanding of web application security concepts
- Familiarity with basic web vulnerabilities (XSS, CSRF, SQLi…)

d. Targeted audience

- Laravel developers
- Security professionals
- Dev(Sec)Ops engineers

e. Program

Global configuration

- Basic PHP security

- Global configuration
- Sessions
- *APP_KEY*

The basics
- Raw PHP in views
- Inputs validation
- Logging and Error handling
- Updates and Backups
- Tricking bots

Cookies & sessions
- Global configuration
- Laravel specific
- Session fixation

Passwords & encryption
- Encrypt/decrypt data
- Passwords validation
- Reset passwords

Authentication & permissions
- Official packages
- Laravel passport
- Gates and policies
- Users / roles / permissions

Rate limiting
- Usage
- Ratelimit actions / routes

File uploads & file storage
- What is it?
- Validation rules and Sanitization
- Storages configuration and usage
- Authorization / permissions / visibility

Mass assignment
- What is it?
- Expectation vs. reality
- How to protect?

Excessive data exposure
- What is it?
- How to protect?
- Take away

SQL Injection (SQLi)

- What is it?
- Prepared statements
- Parameter binding
- Dangers
- Take away

Cross-Site Scripting (XSS)

- What is it?
- Controllers
- Templates
- Input sanitization
- External helps

Cross-Site Request Forgery (CSRF)

- What is it?
- CSRF token
- Middleware
- Forms
- *X-csrf-token* and *X-xsrf-token*

Cross-Origin Resources Sharing (CORS)

- What is it?
- Configuration
- *allowed_origins* and *supports_credentials*